The POWER PULSE UTILITIES

Venerability Assessment Report

November 17, 2024

Prepared by: Azeez O. Yusuff

Executive Summary

This report presents findings from a vulnerability assessment conducted by Algorithm Industrial Security for Power Pulse Utilities on January 4th, 2024. The goal of this assessment report is to evaluate the security vulnerabilities identified within Power Pulse Utilities' systems and network infrastructure. This report evaluates the vulnerabilities identified from both an exploitability and impact perspective and recommends potential mitigation strategies.

This report contains security gaps identified during the assessment as well as tactical and strategic recommendations to address the findings. The table below illustrates the number of findings of various severity levels discovered through this engagement.

Critical	High	Medium	Low
1	1	1	0

Project Scope

The scope that Algorithm Industrial Security reviewed as part of this assessment included:

- **Scope 1:**

  All 40 windows desktops and laptops in use at Power Pulse Utilities.

- **Scope 2**

  6 Siemens Remote Terminal Units (RTUs) (Spread across 3 Distribution Stations)

- **Scope 3**

  35 Cisco SIP Phone 3905 used at Power Pulse's head office

Strengths

Through this review of the Power Pulse Utilities, Algorithm Industrial Security identified a number of strengths including the following:

- **Strength 1**

The firewall protection at Power Pulse Utilities' 3 distribution stations, which ensures all traffic traveling to the station across Power Pulse Utilities' wide area networks needs to pass through a firewall located at each station is a strength worth-noting.

- **Strength 2**

Another notable strength is the routing of calls from clients to a separate call center operated by a third-party organization.

- **Strength 3**

Restricted internet access which requires an attacker to get access to connect to the local network at the distribution stations to exploit devices at these locations is also worth-mentioning.

Weaknesses

In addition to the strengths identified above, a number of weaknesses have been identified that if addressed present an opportunity for Power Pulse Utilities, to improve their security posture significantly.

- **Weakness 1**

Improper neutralization of special elements in Zoom Desktop Client for Windows and Zoom VDI Client before 5.15.2 may allow an unauthenticated user to enable an escalation of privilege via network access. (CVE-2023-39213).

- **Weakness 2**

The network configuration service of affected devices contains a flaw in the conversion of ipv4 addresses that could lead to an uninitialized variable being used in succeeding validation steps.

- **Weakness 3**

Ability of an authenticated, remote attacker to conduct an XSS attack against a user of the interface on the affected device and execute arbitrary script code in the context of the affected interface or access sensitive, browser-based information.

Strategic Recommendations

Algorithm Industrial Security recommends that Power Pulse Utilities take the following actions to build a comprehensive security program:

- **Recommendation 1**

The version of Zoom Client for Meetings installed on the remote host should be upgraded to Zoom Client for Meetings 5.15.2 or later

- **Recommendation 2**

Power Pulse Utilities should refer to vendor advisory regarding the vulnerabilities identified.

- **Recommendation 3**

Here, upgrade to the relevant fixed version referenced in Cisco bug IDs CSCwfr58592, CSCwf58594 Is highly recommended.

Introduction

Power Pulse Utilities, a local electricity distribution company, serves 30,000 people using a mix of residential, commercial, and light industrial electricity. As Power Pulse is a small electricity distribution organization, with 40 employees, a head office and 3 distribution stations, everyone in the organization serves many roles.

A couple of weeks ago, the company hired a third-party consulting company- Algorithm Industrial Security – to conduct a vulnerability scan of its assets on both its IT and OT networks. From the report submitted by Algorithm Industrial Security, Karen, the Head of IT at Power Pulse Utilities, provided some background information:

ZOOM CLIENT FOR WINDOW DESKTOP

This software is installed on all 40 Windows desktops and laptops that are used by Power Pulse employees, containing client's confidential information and about Power Pulse's operations.

SIEMENS REMOTE TERMINAL UNITS

The 6 Siemens Remote Terminal Units (RTUs) that appear on the report are located at Power Pulse's 3 distribution stations. Protected by a firewall, all traffic traveling to the station across Power Pulse's wide area networks needs to pass through a firewall located at each station. Therefore an attacker would need to get onto the local network to exploit devices located in the 3 stations, although internet access is not available from the station networks.

CISCO

The Cisco vulnerability that appears on the report impacts 35 SIP phones (model 3905) that are all located at Power Pulse's head office. Considered of low importance from a confidentiality, integrity, and availability perspective, they aren't used that often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues. All calls from clients are routed to a separate call center operated by a third-party organization.

Acknowledging that the Algorithm Industrial Security didn't actually analyze the vulnerability scanner output, this report aims to conduct some further research on the vulnerabilities that appear in the scan report to understand and present the following:

• A high level summary of each vulnerability.

• Whether the vulnerabilities are currently being exploited.

• A description of what the potential impact of these vulnerabilities could be to Power Pulse's operations and/or customers.

• An assessment of the vulnerabilities, based on where the vulnerable assets reside within Power Pulse's network. Parameters such as the sensitivity of the data on the vulnerable assets or compensating controls that may increase or decrease the severity of the vulnerability should be considered.

• How the vulnerabilities should be prioritized.

• A recommended plan of action to address each of the vulnerabilities.

Identification of Vulnerabilities

The results from the recent vulnerability scan produced these three vulnerabilities:

Vulnerability #1: Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038)

Vulnerability #2: Siemens (CVE-2023-42797)

Vulnerability #3: Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)

Analysis Using Vulnerability Databases

After reviewing the three vulnerabilities in various sources including, Tenable's Vulnerability Plug-In Database, NIST's National Vulnerability Database, CVSS and CISA's Cybersecurity Alerts & Advisories site, this is what was discovered:

Vulnerability #1: Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038)

This vulnerability results when the version of Zoom Client for Meetings installed on the remote host is prior to 5.15.2. It is, therefore, affected by a vulnerability as referenced in the ZSB-23038 advisory.

- Improper neutralization of special elements in Zoom Desktop Client for Windows and Zoom VDI Client before 5.15.2 may allow an unauthenticated user to enable an escalation of privilege via network access. (CVE-2023-39213).

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

The Base score as per CVSS v3.0 for this vulnerability is 9.8 or Critical.

Vulnerability #2: Siemens (CVE-2023-42797)

This vulnerability results when specially crafted network configuration are uploaded giving an authenticated remote attacker access to inject commands that are executed on the device with root privileges during device startup and result in an uninitialized variable being used in succeeding validation steps.

The Base score as per CVSS v3.0 for this vulnerability is 7.2 or High.

Vulnerability #3: Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)

Cisco IP Phone Stored XSS contains insufficient validation of end-user supplied input. Due to this situation, an authenticated, remote attacker can conduct an XSS attack against a user of the interface on the affected device. A successful exploit could allow the attacker to execute arbitrary script code in

the context of the affected interface or access sensitive, browser-based information. To exploit this vulnerability, the attacker must have valid credentials to access the web-based management interface of the affected device.

The Base score as per CVSS v3.0 for this vulnerability is 5.4 or Medium.

Determination of Exploitability

Vulnerability #1: Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038)

- No known exploits are available for this vulnerability as indicated in https://www.tenable.com/plugins/nessus/184369 for this vulnerability.
- The Base score as per CVSS v3.0 for this vulnerability is 9.8 or Critical.
- The Attack Vector is network based, the Attack Complexity is Low, Privileges are not required and User Interaction is not required.

Vulnerability #2: Siemens (CVE-2023-42797)

- No known exploits are available for this vulnerability as indicated in https://www.tenable.com/plugins/ot/501888 for this vulnerability.
- The Base score as per CVSS v3.0 for this vulnerability is 7.2 or High.
- The Attack Vector is network based, the Attack Complexity is Low, Privileges are required and User Interaction is not required.

Vulnerability #3: Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)

- No known exploits are available for this vulnerability as indicated in https://www.tenable.com/plugins/nessus/186612 for this vulnerability.
- The Base score as per CVSS v3.0 for this vulnerability is 5.4 or Medium.
- The Attack Vector is network based, the Attack Complexity is Low, Privileges are Low and User Interaction is required.

Impact Analysis

This is the impact of the top three vulnerabilities that were found:

Vulnerability #1: Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038):

Since the vulnerable Zoom Client for Meetings uses software that is installed on all 40 windows desktops and laptops used by all Power Pulse Utilities' employees, and contains client's confidential information and about Power Pulse Utilities' operations, clients' personal information and the company's operations are at high risk of being compromised.

Vulnerability #2: Siemens (CVE-2023-42797)

This is a vulnerability in 6 Siemens Remote Terminal Units (RTUs) located at Power Pulse Utilities' 3 distribution stations. Although these stations are each protected by a firewall - an attacker would

require internet access and need to get onto the local network to exploit devices located in the 3 stations, and all traffic traveling to the station across Power Pulse's wide area networks needs to pass through a firewall located at each station, the impact will be high if the Siemens Remote Terminal Units are compromised.

Vulnerability #3: **Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)**

The Cisco vulnerability impacts 35 SIP phones (model 3905) that are all located at Power Pulse Utilities' head office. As they aren't used that often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues and all calls from clients are routed to a separate call center operated by a third-party organization, the impact is medium as these devices are considered of low importance from a confidentiality, integrity, and availability perspective.

Contextualization

As this system contains sensitive data and is Internet-facing, I submit that the environmental metrics support the fact that this vulnerability is urgent in nature. It is important to note that there is no any compensating controls that would lower the risk associated with this vulnerability.

Vulnerabilities should be assessed based on the environment in which the vulnerability resides. For example, a vulnerability in a development environment may have a different risk level than the same vulnerability in a production environment.

Business context should be considered, such as the importance of the system from a business process perspective.

Consideration should be given to compensating controls that can mitigate risk. The CVSS 3.1 calculator has been used to determine an adjusted score for each vulnerability based on the Environmental Scores.

Vulnerability #1: **Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038):**

These are the overall scores for the Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038)

Base Score	Temporal Score	Environmental Score
9.8 (Critical)	**8.5 (High)**	**8.5 (High)**

The Zoom Client for Meetings being affected by this vulnerability is external facing and contains client's confidential information and about Power Pulse Utilities' operations.The availability and integrity of the systems is important. Since these systems contain client's confidential information and about Power Pulse Utilities' operations and are external facing, the environmental metrics support the fact that this vulnerability is urgent in nature.

The CVSS 3.1 calculator was used to calculate an environmental score for this vulnerability. The environmental severity of this vulnerability is 8.5 (High).

https://www.first.org/cvss/calculator/3.1#CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C/CR:H/IR:H/AR:H

Vulnerability #2: Siemens (CVE-2023-42797)

These are the overall scores for Siemens (CVE-2023-42797)

Base Score	Temporal Score	Environmental Score
7.2 (High)	**6.3 (Medium)**	**4.6 (Medium)**

This is a vulnerability in 6 Siemens Remote Terminal Units (RTUs) located at Power Pulse's 3 distribution stations. The Confidentiality, Integrity and Availability requirements for the Remote Terminal Units (RTUs) are low.

Additionally, the stations are firewalled, so the Modified Attack Vector can be set as Adjacent, as an attacker would require internet access and need to get onto the local network to exploit devices located in the 3 stations to exploit this vulnerability.

The overall Environmental Score is 4.6 (Medium), which is much lower than the base score, which reflects the fact the stations are firewalled and all traffic traveling to the station across Power Pulse Utilities' wide area networks needs to pass through a firewall located at each station.

The CVSS 3.1 calculator was used to calculate an environmental score for this vulnerability. The environmental severity of this vulnerability is 4.6 (Medium).

https://www.first.org/cvss/calculator/3.1#CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:U/RL:O/RC:C/CR:L/IR:L/AR:L

Vulnerability #3: Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)

These are the overall scores for Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)

Base Score	Temporal Score	Environmental Score
5.4 (Medium)	**4.7 (Medium)**	**3.5 (Low)**

The Cisco vulnerability impacts 35 SIP phones (model 3905) that are all located at Power Pulse's head office. The impact is low as these devices are considered of low importance from a Confidentiality, Integrity and Availability requirements perspective.

Notably, all calls from clients are routed to a separate call center operated by a third-party organization, so the Modified Attack Vector can be set as Adjacent, as employees aren't using the devices often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues. Should an attacker access and exploit this vulnerability, the impact will be very low.

The overall Environmental Score is 3.5 (Low), which is much lower than the base score, which reflects the fact that all calls from clients are routed to a separate call center operated by a third-party organization and all employees aren't using the devices often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues

The CVSS 3.1 calculator was used to calculate an environmental score for this vulnerability. The environmental severity of this vulnerability is 3.5 (Low).

https://www.first.org/cvss/calculator/3.1#CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:L/IR:L/AR:L

Threat Environment

In 2022, energy companies in North America suffered 20% of attacks, making energy the most attacked industry.

The type of attacks varied with 40% starting by cyber criminals exploiting public-facing applications. Spear phishing links and external remote services made up 20% of energy attacks. Other types of attacks included data theft (23%), extortion (23%), ransomware (15%), BEC (15%), credential harvesting (15%) and botnet infections (19%).

With Russia's invasion of the Ukraine, concern over cyberattacks on the energy grid, especially from the Killnet group have increased. The energy sector fits Killnet's attack profile for distributed denial of service (DDoS) threats.

Given the increased attacks against the North American energy sector over the past couple of years, Algorithm Industrial Security recommends that Power Pulse Utilities remain vigilant against the threat of potential attacks from high profile threat actors.

Prioritization

Vulnerability#	Recommended Implementation Timeframe	Rationale
#1- Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038)	Should be addressed within 14 days as they can pose a significant risk and can be exploited by threat actors.	Client's confidential information and about Power Pulse Utilities' operations are potentially at risk and are external facing.
#2 - Siemens (CVE-2023-42797)	Should be addressed within 30 days as they present a moderate risk and can potentially be exploited with other vulnerabilities	The stations are firewalled - All traffic traveling to the station across Power Pulse Utilities' wide area networks needs to pass through a firewall located at each station. Internet access limited and an attacker would need to get onto the local network to exploit devices at these stations
#3 - Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA)	Should be remediated within 90 days. These vulnerabilities present a minimal threat on their own but should be addressed to maintain system security and hygiene.	Given the fact that all calls from clients are routed to a separate call center operated by a third-party organization, all employees aren't using the devices often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues, and the relatively low probability and impact of the vulnerability being exploited

Plan of Action

The most critical vulnerability that Algorithm Industrial Security assessed as part of this engagement is the Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038) on Power Pulse Utilities' is external facing and resides on the Zoom Client for Meetings devices, which contains client's confidential information and about Power Pulse Utilities' operations. This vulnerability could result in the exposure of customer personal information and greatly impacts the company's operations, and should be remediated as quickly as possible, within 14 days specifically, by upgrading the version of Zoom Client for Meetings installed on the remote host to Zoom Client for Meetings 5.15.2 or later.

The next vulnerability that should be addressed is the 6 Siemens Remote Terminal Units (RTUs) that are located at Power Pulse's 3 distribution stations, which should be addressed within 30 days as they present a moderate risk and can potentially be exploited with other vulnerabilities.The recommended course of action in this case is to refer to vendor advisory regarding the vulnerabilities identified.

The vulnerability on Cisco IP Phone Stored XSS (cisco-sa-uipphone-xss-NcmUykqA) presents the lowest level of risk to Power Pulse Utilities, given the fact that all calls from clients are routed to a separate call center operated by a third-party organization, all employees aren't using the devices often since most employees use their corporate cell phones or the Zoom client on their computers to call colleagues, and the relatively low probability and impact of the vulnerability being exploited.

This vulnerability should be remediated within 90 days as these vulnerabilities present a minimal threat on their own but should be addressed to maintain system security and hygiene.

Here, upgrade to the relevant fixed version referenced in Cisco bug IDs CSCwfr58592, CSCwf58594 Is highly recommended.

Conclusion

This vulnerability assessment has revealed a critical vulnerability, one high, one medium and a low-priority vulnerability in Power Pulse Utilities' environment. These vulnerabilities, if left unchecked, could potentially lead to unauthorized access, data breaches, and other security incidents that could have impacts on Power Pulse Utilities' operations and reputation.

The most notable vulnerability discovered is a Zoom Client for Meetings < 5.15.2 Vulnerability (ZSB-23038) on Power Pulse Utilities, an external facing vulnerability, which contains client's confidential information and about Power Pulse Utilities' operations. This vulnerability could result in the exposure of customer personal information and greatly impacts the company's operations, and should be remediated as quickly as possible, within 14 days specifically, by upgrading the version of Zoom Client for Meetings installed on the remote host to Zoom Client for Meetings 5.15.2 or later.

The other two vulnerabilities should be remediated as outlined in the Prioritization and Plan of Action sections and based on Power Pulse Utilities' Vulnerability Management standard.

Algorithm Industrial Security recommends that Power Pulse Utilities remediate the vulnerabilities outlined in this report in line with the detail contained in the Prioritization and Plan of Action sections of this report. Power Pulse Utilities' proactive efforts in addressing these issues will play a vital role in safeguarding the organization against future cyber threats.